

Information Security Management

Organizational Security

IT-Sicherheit | 18.03.2026

Gerald Dißbaur | Lecturer

A-SIT Secure Information Technology Center Austria

Agenda

Introduction

ISMS – Fundamental Principles about ISO/IEC 2700x

Building an ISMS – Processes, Documentation, Facts

Practical Experiences from Conducted Projects

Discussions & Summary

Agenda

Introduction

ISMS – Fundamental Principles about ISO/IEC 2700x

Building an ISMS – Processes, Documentation, Facts

Practical Experiences from Conducted Projects

Discussions & Summary

LECTURE OBJECTIVE

WHY DO WE NEED INFORMATION SECURITY MANAGEMENT?

Explore formal Information Security Management Systems (ISMS)

under ISO¹/IEC² 2700x

to

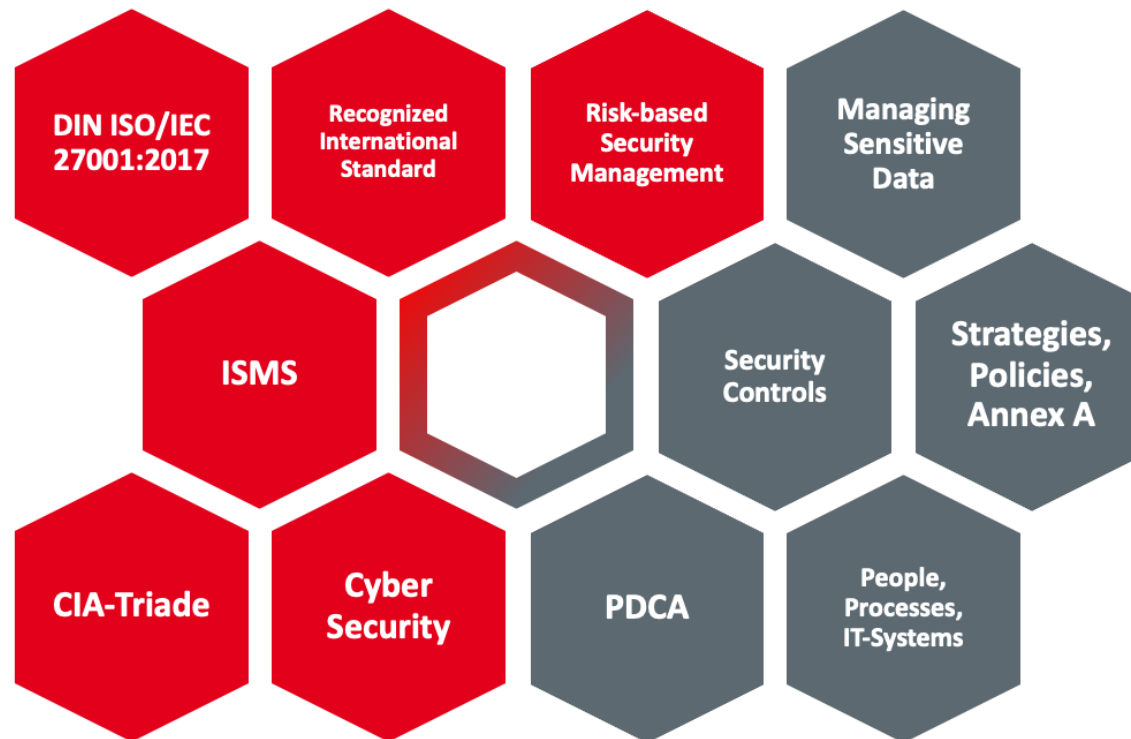
build such systems for Organisations that face privacy and information security concerns

to ensure that

arising risks are addressed and Information Security is continuously managed

Nice – But why?

KEYWORDS



RECENT OBSERVATIONS FROM INDUSTRY SOFTWARE IS UNDER MALICIOUS ATTACK

08/2017 | “While they may not always feel glamorous, strong **managerial processes** really **matter**. It’s great that **Google** made its **public** [...]”¹

2018 | “More and more organizations are accepting the fact that, despite their best efforts, **security breaches** are **unavoidable**. [...] It’s not a question **IF** your network will be breached, **the only question is WHEN**”²

¹ cf. (Sadun, 2017)

² cf. (Gemalto NV., 2018, p. 2, p. 16)

RECENT OBSERVATIONS FROM INDUSTRY | cont'd

100% SECURITY VERY HARD¹ TO ACHIEVE

05/2018 | *"I've been getting some weird press calls from reporters wanting to know if this demonstrates that e-mail encryption is impossible. No, this just demonstrates that **programmers are human and vulnerabilities are inevitable**. PGP² almost certainly has **fewer bugs than your average piece of software, but it's not bug free**."*³

09/2018 | *"No matter how much **resources** you **spend** for **security** systems, you become **not** completely **protected** against hacker **attacks**."*⁴

09/2019 | *"Technology alone can not protect a network."*⁵

¹ Which means it is almost impossible to be 100% secure

² PGP – Pretty Good Privacy

³ cf. (Schneier, 2018)

⁴ cf. (Bochman, 2018, p. 38); (G. Dißauer, Trans.) (Original work published 09/2018)

⁵ cf. (Winnefield, Kirchhoff, Upton, 2019, p. 21); (G. Dißauer, Trans.) (Original work published 02/2019)

WHY DO WE NEED INFORMATION SECURITY? INFORMATION ARE VALUABLE ASSETS

- Automotive security
- Aerospace systems
- Payment systems
- Electronic identities
- Healthcare Information Systems
- Internet of Things (IoT)

„Information are valuable assets“

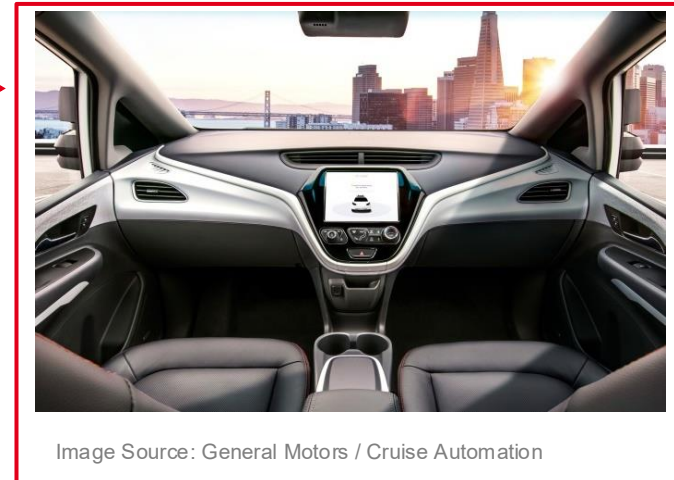


Image Source: General Motors / Cruise Automation

LEGAL RESTRICTIONS AND OBLIGATIONS

EXAMPLES FOR LEGISLATIVE BASES

Legislation not necessarily requires ISO/IEC 27001 but implicitly

Examples:

- eIDAS/eIDAS2 (Regulation 910/2014 amended by 2024/1183) requires Art. 21 NIS2 (Directive 2022/2555)¹
- Cyber Security Act (Regulation 2019/881) for certification of IT-products, services and processes
- Cyber Resilience Act (Regulation 2024/2847)

eIDAS/eIDAS2

eIDAS/eIDAS2 puts an emphasis on

- digital identities
- EUDI-Wallets
- qualified services (e.g., operation of a remote QSCD, signatures, seals, timestamps, etc.)
- for cybersecurity risks it makes a conjunction to NIS2 Directive – affected are qualified trust service providers

CSA – CYBER SECURITY ACT

CSA puts an emphasis on

- strengthening ENISA
- Cybersecurity certification mechanism for products, services and processes
- Certification for levels basic, substantial and high

CRA – CYBER RESILIENCE ACT

Main components of CRA

- Perform a cyber security risk assessment
- Implement security by design and by default
- Install a secure software lifecycle
- Maintain a change management process (for the product)
- Threat Intelligence and vulnerability management process
- Reporting obligations to oversight
- Conformity assessments by accredited conformity assessment bodies

INTERMEDIATE CONCLUSION?

Fundamental for development and operation of (critical) IT systems

- Risk Assessment (e.g., architectural, continuous, ...)
- Risk Register
- Secure Software Lifecycle (i.e., applying security controls to lifecycle of systems and data)
- Threat Intelligence process (including evaluation of threats, public sources etc.)
- Reporting procedures to be implemented in case of incidents

KEY PROBLEMS OBSERVATIONS

- **Increasing complexity.** Growing amount of functions, more linked networking, integrating heterogeneous systems, alternative versions
- **Progressive cost pressure.** Cut-throat competition and the demand of lower prices result in decreasing budgets
- **High speed development.** Short time-to-market, more competition, and reduced development time demand available products
- **Software-driven innovation.** Software is a critical factor of success, it realizes innovative systems capabilities (e.g. BCI, IoT, QES)
- **Excess quality demands.** The requirements in terms of quality broaden (e.g. Automation, Availability, Throughput, Vulnerabilities).

SOME STATISTICS | RECAP

SELECTED NUMBERS FROM KPMG STUDY¹

8%

of businesses **don't** trust the security measures of their contractors

18%

of businesses **don't** know whether they have been attacked

27%

of businesses trust their own security measures

¹ KPMG Security Services GmbH (2020). *Cyber Security in Österreich, Studie, Advisory*, Vienna, Austria

Agenda

Introduction

ISMS – Fundamental Principles about ISO/IEC 2700x

Building an ISMS – Processes, Documentation, Facts

Practical Experiences from Conducted Projects

Discussions & Summary

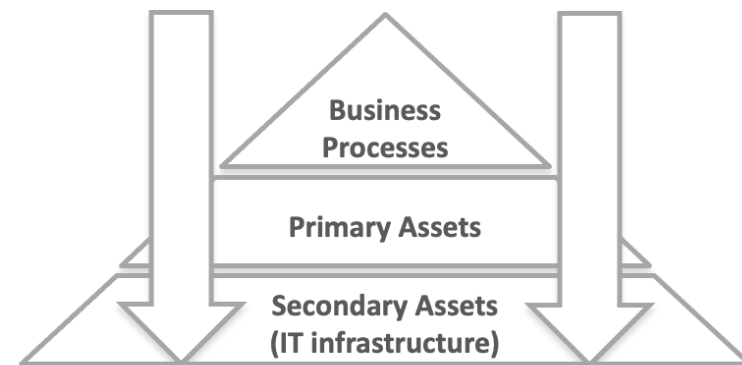
BASIC APPROACH TOP DOWN

Idea

- Starting point: Business processes
- Approach: Targeted protection of selected components depending on the protection requirements of related business processes
- Goal: Security of organization's business processes

Pros/Cons

- Efficient use of resources
- Complete overview of organization required (risk model)
- Compliance with standards
- Structured approach



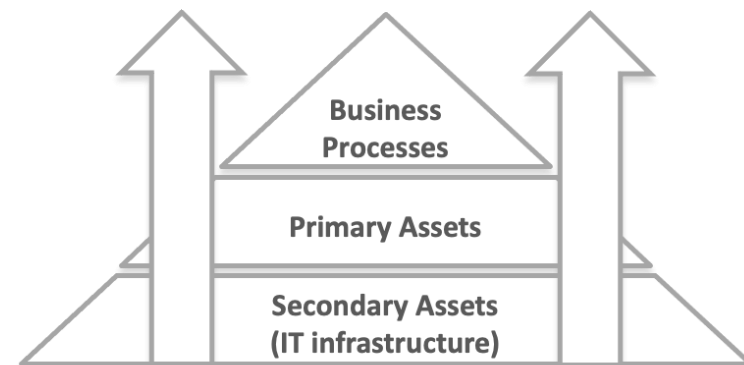
BASIC APPROACH BOTTOM UP

Idea

- Starting point: IT infrastructure
- Approach: Best possible protection of all components
- Goal: Security of organization's business processes

Pros/Cons

- Easy to apply, easy to modularize
- Inefficient use of resources
- Missing organization-wide overview



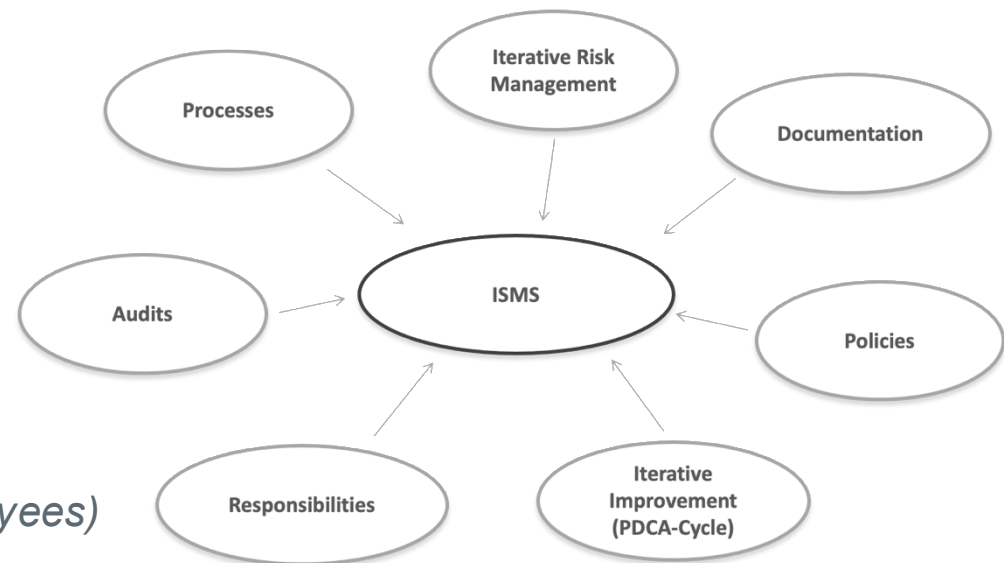
ISMS BUILDING BLOCKS AN OVERVIEW

ISMS Scope

- Self-defined (*often critiqued*)
- Not only IT business units

An ISMS affects

- Processes
- Systems
- People (*e.g., management, employees*)



Own figure based on (Zefferer, 2021)

Achieve objectives – but which objectives?

CIA-TRIAD | CORE CONCEPT TO PROTECT ASSETS

ALTERNATIVES ARE AVAILABLE

Information security guideline defines the information security objectives („*protection targets*“) to protect information assets (e.g., *classified information*) with **security controls**

- Confidentiality
 - Integrity
 - Availability
 - Authenticity
 - Non-repudiation
 - Reliability
 - Access Control
 - Accountability
- **CIA-Triade** (*alternatively CI5A¹ possible*)

¹ CI5A – Confidentiality, integrity, availability, authentication, authorization, accounting, and anonymity

ASSETS | INVENTORY | CLASSIFICATION

SELECTED EXAMPLE

Inventory of **assets** required

Classification of information **assets** required to derive suitable **security controls**

- Public
- Internal
- Restricted
- Confidential
- Secret
- Top Secret

Add a Color Code

*§ 2 (2) „Bundesgesetz über die Umsetzung
völkerrechtlicher Verpflichtungen zur sicheren
Verwendung von Informationen
(Informationssicherheitsgesetz, InfoSiG)“*

ORGANIZATIONAL AND TECHNICAL SECURITY CONTROLS

A DISTINCTION



One can distinguish between

- (1) **Organizational security controls** (e.g., *ISMS, documentation, awareness, data backup, principle, managerial approaches, processes, audits, assessments, policies, standards, baselines*)
- (2) **Technical security controls** (e.g., *AES¹, ECDSA², firewalls, RSA³, parameter length, key length, sandboxing, VPN⁴, WAF⁵*)

Sometimes Hybrid Controls are in Place

¹ AES – Advanced Encryption Standard

² ECDSA – Elliptic Curve Digital Signature Algorithm

³ RSA – Rivest Shamir Adleman

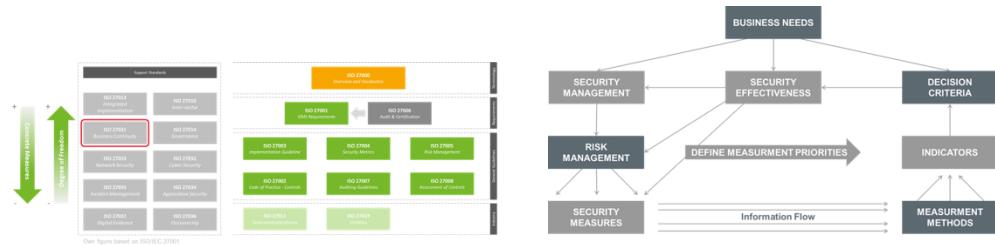
⁴ VPN – Virtual Private Network

⁵ WAF – Web Application Firewall

HOW CAN WE CLASSIFY SECURITY CONTROLS?

4 GROUPS OF SECURITY CONTROLS AGGREGATED

- **Preventive** (< 100%, *encryption*)
- **Detective** (e.g., *IDS¹, IPS²*)
- **Reactive** (*measures, etc.*)
- **Communication**
(e.g., *escalation, emergency management, crisis management*)



Combine both organizational and technical security controls

WHAT IS THE ISO/IEC 2700x?

GENERAL OVERVIEW

An internationally recognized top down **information security management** standard

- Recognized security standards such as ISO 27001 are meaningfully
- ISO 27001 is a general security standard (*i.e., provides guidelines*)
- Includes explanations of security management concepts
- Not very complex, but a lot of efforts – Certification (only for 27001) feasible
- Explains how to deal with these security issues without restricting itself to a specific methodology

THE FUNDAMENTAL BASIS OF AN ISMS

ISO/IEC 27001

- Lifecycle of risk assessments
 - Security controls (*development and examination*)
 - C-level oversight and control
-
- Understanding an organization's information security requirements
 - Build and run controls to manage an organization's information security
 - Monitoring and reviewing the ISMS
 - Continuous improvement of ISMS

WHICH ASPECTS DOES ISO/IEC 27001^{1,2} COVER?

3 GENERAL ASPECTS

A family of information security standards which addresses the following aspects:

- **Terminology** (e.g., *information are interpreted data that are of particular value for organisations*)
- **Managementsystem** for organisations
- **114 security controls³** (corresponding to **14 categories** i.e., „*reference control objectives*“)

Objective: Obtain a High Degree in Terms of Information Security

¹ Annotation: The latest published version to date is ISO/IEC 27001:2013

² cf., Information technology – Security techniques – Information security management systems – Requirements

³ Annotation: One can find those controls in Annex A of the respective standard. Those are also given in more details in ISO/IEC 27002

GENERAL METHODOLOGY

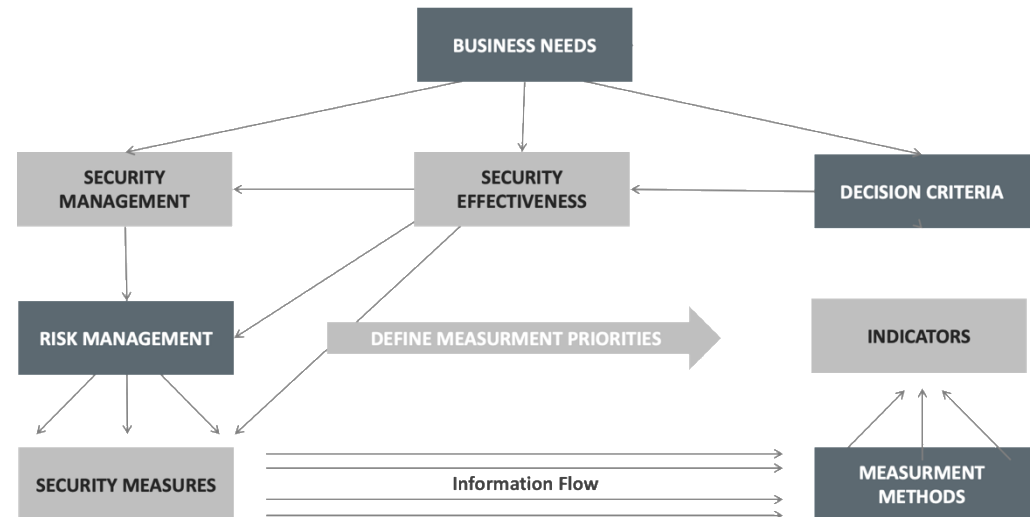
HOW TO IMPLEMENT AN ISMS

- (1) **Identify assets** (*e.g., primary and secondary assets; mainly information or data, premises, cryptographic key material – i.e., value for the organisation*) and segment it where useful
- (2) **Establish a framework** (*basis for ISMS*) including policies, processes, and procedures
- (3) **Create, publish** (*e.g., internally*) and **maintain documentation**
- (4) **Address and assign responsibilities**

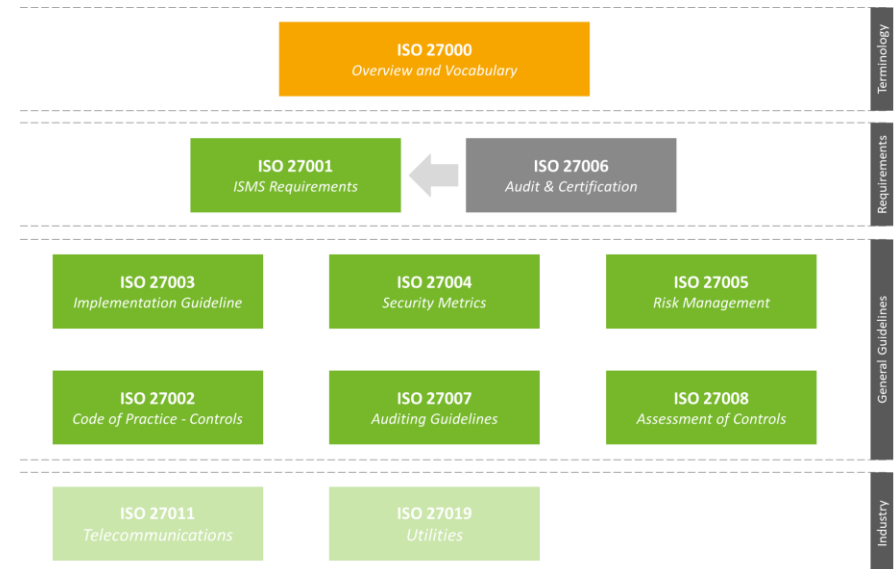
SECURITY MANAGEMENT

THE BIG PICTURE CONSOLIDATED

- Risk-based approach
- Assess and evaluate risks
- Derive security measures
- Decide on security measures



WHAT IS THE STRUCTURE OF THE ISO/IEC 2700x FAMILY? CONSOLIDATED



REFERENCE CONTROL OBJECTIVES

14 CATEGORIES

- A.5 Information security policies
- A.6 Organisation of information security
- A.7 Human resource security
- A.8 Asset management
- A.9 Access control
- **A.10 Cryptography**
- A.11. Physical and environmental security
- **A.12 Operations security**
- A.13 Communications security
- A.14 System acquisition, development, and maintenance
- A.15 Supplier relationships
- A.16 Information security incident management
- A.17 Information security aspects of business continuity management
- A.18 Compliance

27001 | A.10 CRYPTOGRAPHY

SELECTED EXAMPLE | ANNEX A

A.10.1.1 Policy on the use of Cryptographic Controls

- Policy required to be developed and implemented to apply cryptography
- Protect data / information with cryptography

A.10.1.2 Key Management

- Policy required to be developed and implemented to use cryptographic key material
- Total key lifecycle, its protection, validity period

>> No Particular Techniques Suggested – A General Process <<

A.12 OPERATIONS SECURITY

SELECTED EXAMPLE

A.12.1.1 Documented Operating Procedures

A.12.1.2 Change Management

A.12.1.3 Capacity Management

A.12.1.4 Separation of Development, Testing & Operational Environments

A.12.2.1 Controls Against Malware

A.12.3.1 Information Backup

[...]

RECENT OBSERVATIONS

NEW VERSION ISO 27001

- Latest version: 2022
- Main impacts are changes to 27001 Annex A (*i.e., in conjunction with 27002*)
- **Controls are grouped into 4** instead of 14
- Total number of security controls updated 93 (*from formerly 114*)
- **11 new security controls** (*no deleted, but some merged*)
- **5 Categories for each security control**
- Clauses 4 to 10 are not changed (*27002*)
- 35 controls stayed the same 23 were renamed

THE 4 CONTROL GROUPS

ISO 27001 UPDATED

- **A.5 Organizational Controls (A.5.1 to A.5.37)**
- **A.6 People Controls (A.6.1 to A.6.8)**
- **A.7 Physical Controls (A.7.1 to A.7.14)**
- **A.8 Technological Controls (A.8.1 to A.8.34)**

Consolidated and simplified

11 NEW SECURITY CONTROLS

ISO 27001 UPDATE

- **A.5.7 Threat intelligence** (*Information relating to information security threats shall be collected and analysed to produce threat intelligence*)
- **A.5.23 Information security for the use of cloud services** (*Processes for acquisition, use, management and exit from cloud services shall be established in accordance with the organization's information security requirements.*) some kind or organizational security control
- **A.5.30 ICT readiness for business continuity** (*ICT readiness shall be planned, implemented, maintained and tested based on business continuity objectives and ICT continuity requirements.*)
- **A.7.4 Physical security monitoring** (*Premises shall be continuously monitored for unauthorized physical access.*)
- **A.8.9 Configuration management** (*Configurations, including security configurations, of hardware, software services and networks shall be established, documented, implemented, monitored and reviewed.*)

11 NEW SECURITY CONTROLS | cont´d

ISO 27001 UPDATE

- **A.8.10 Information Deletion** (*Information stored in information systems devices or in any other storage media shall be deleted when no longer required) cf., GDPR*)
- **A.8.11 Data Masking** (*Data masking shall be used in accordance with the organization´s topic-specific policy on access control and other related topic-specific, and business requirements, taking applicable legislation into account*)
- **A.8.12 Data leakage prevention** (*Data leakage prevention measures shall be applied to systems, networks and any other device that process, store or transmit sensitive information*)
- **A.8.16 Monitoring Activities** (*Networks, systems and applications shall be monitored for anomalous behaviour and appropriate actions taken to evaluate potential information security incidents, balanced*)
- **A.8.23 Web Filtering** (*Access to external websites shall be managed to reduce exposure to malicious content*)
- **A.8.28 Secure Coding** (*Secure coding principles shall be applied to software development*)

11 NEW SECURITY CONTROLS | cont´d

ISO 27001 UPDATE

- Control Type – Preventive, Detective, Corrective (*i.e., when to be implemented in the lifecycle*)
- Target Security Properties – Confidentiality, Integrity, Availability (*i.e., security objectives*)
- Cybersecurity Concepts – Identify, Protect, Detect, Respond, Recover (*similar to NIST Cyber Security Framework*)
- Operational Capabilities (*from operational people „reality perspective“: Governance, Asset Management, Information Protection, Human Resource Protection, Physical Security ... up to Security Assurance*)
- Security Domains – Governance and Ecosystem, Protection, Defense, Resilience

NEW CONSOLIDATED SECURITY CONTROLS

SELECTED EXAMPLES

Selected examples are:

- **Storage Media.** Target: data loss prevention, increase availability, strengthen integrity. Data lifecycle and classifications to be used. Emphasis on withdrawal or re-use of media covering rules to use/store/manage/encrypt/track/register how to deal with storage media,
- **Application Security Requirements.** Network communications and application transactions consolidated (from 27001:2013). Now simplified and more precise. Covering also: Confidentiality and Integrity of order data (for purchases etc.), payment data of customers)
- **User Endpoint Devices.** Policies to cover particularly mobile devices. Emphasis on registration of such devices. Restrictions for installation of software, Update/Patch-mechanisms, Malware protection amongst others.

INFORMATION SECURITY MANAGEMENT A CYCLE

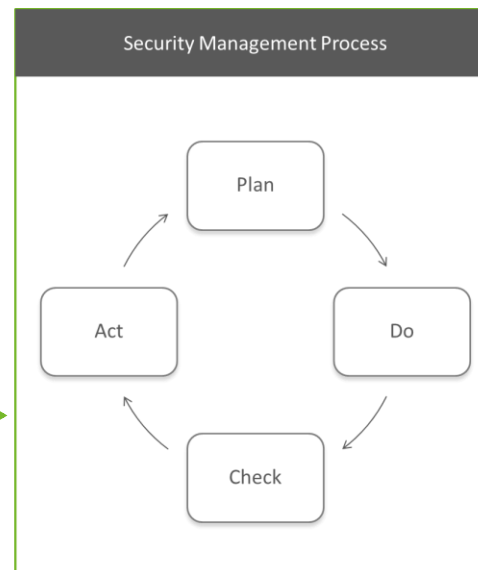
General Process in conjunction with PDCA-cycle



¹ SoA – Statement of Applicability

CONJUNCTIONS TO A SECURITY MANAGEMENT PROCESS OBTAINED FROM QUALITY MANAGEMENT

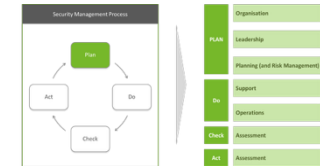
- Building an ISMS
- Operating an ISMS
- Continuous assessment
- **Continuous improvement**
- Security controls
- PDCA-Cycle (or *Deming circle*) →
- PDCA also for certification
- Assign tasks to roles



PLAN PDCA CYCLE

Plan, specify, and install a security management under the corporate policy, the operational requirements, and legal constraints

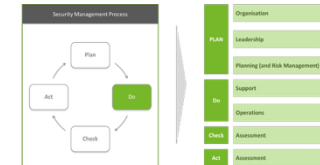
- Define a process model to address security, continuity and risk management
- Gather and identify security, and business continuity requirements
- Create a security, and a business continuity policy
- Develop security concepts
- Execute selected – but balanced (*e.g., risk-based*) – security measures



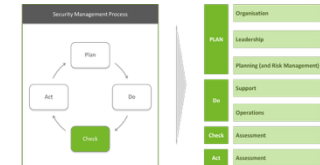
DO PDCA CYCLE

Implement, operate, and monitor the developed ISMS

- Conduct training, and awareness campaigns, regularly
- Operate the ISMS under consideration of defined both security and business continuity concepts
- Quantify and conduct monitoring w.r.t. requirements (detect and escalate)
- Gather data to compare actual performance with target



CHECK PDCA CYCLE



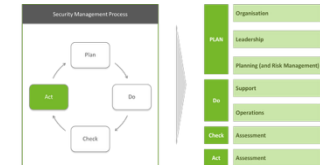
Validate and verify the ISMS, periodically and conduct

- Audits (*e.g., internal ISMS audit, security audits*)
- Tests (*e.g., staging concept, testing the backup method, BCM¹ or recovery plans*)
- Exercises (*e.g., Business Continuity*)
- Security assessments
- Document the derived results, analyze it and evaluate the observations to obtain reports

ACT PDCA CYCLE

Continuously improve the ISMS

- Consider new observations and know how
- Based on changing environments (*e.g., legal constraints, new processes*)
- Identify needs for change
- Prioritize the organisations demand and construct a roadmap (*or a project plan*)



RISK MITIGATION

- **Avoid it** (e.g., steps to stop happening such as disconnecting a system from the internet)
- **Mitigate it** (e.g., by implementing security controls such as encryption, TLS¹)
- **Transfer it** (e.g., outsourcing of software development)
- **Accept it** (e.g., do not implement mitigation controls or residual risks)

Deal with residual risks – residual risks always remain.

You cannot eliminate all risks

¹ TLS – Transport Layer Security

INFORMATION SECURITY LEVEL

IMPACTS, COST OF CONTROL, AND RESIDUAL RISK

- Sufficient security level
- Risk acceptance
- Extent of losses
- Cost of controls

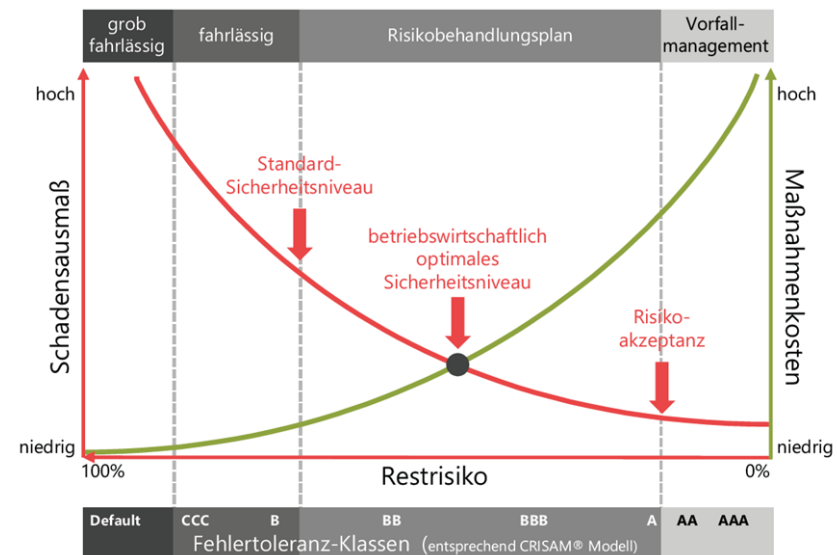
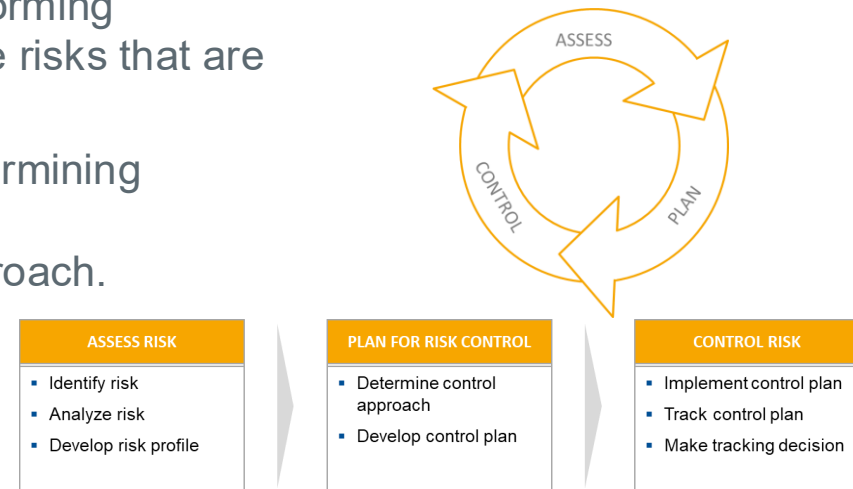


Figure taken from (Hanschke, 2019, p. 4)

IMPLEMENT RISK-BASED SECURITY CONTROLS

Derive balanced i.e., risk-based security controls via a defined process

- **Assess Risk.** Assessment involves transforming concerns people have into distinct, tangible risks that are explicitly documented and analyzed.
- **Plan for Controlling Risk.** It involves determining an approach for addressing each risk and producing a plan for implementing the approach.
- **Control Risk.** Controlling risk involves dealing with each risk by implementing its defined control plan and tracking the plan to completion.



Own figure

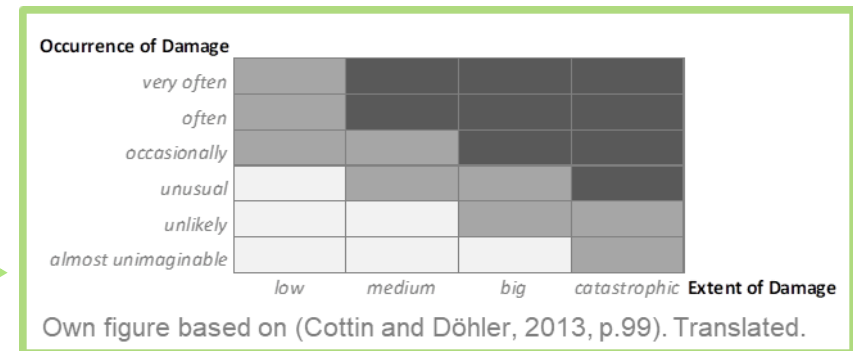
Residual Risks Remain

HANDLE INFORMATION SECURITY RISK

MAIN OBJECTIVE AND TOOL SPECTRUM

Main Objective: Understand relevant risks (*relevant standard e.g.; ISO 31000*)

- Carry out **risk assessment** to detect threats (*e.g., to the supply chain*)
- Conduct **supplier risk assessment** and perform **code-reuse risk assessment**
- Install Risk-Controls and Mitigation-Measures
- **Document** the **outcomes** of the risk assessment
- Selected tool spectrum to illustrate/visualize risk
 - Excel-File
 - Mindmap
 - **Risk Map**
 - Risk Matrix¹
 - Automatic tools (*e.g., CRISAM, Verinice*)



¹ cf. (Cottin and Döhler, 2013, p. 99)

Agenda

Introduction

ISMS – Fundamental Principles about ISO/IEC 2700x

Building an ISMS – Processes, Documentation, Facts

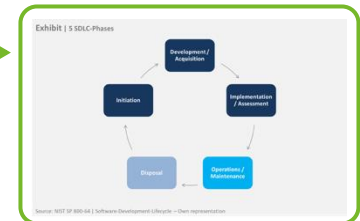
Practical Experiences from Conducted Projects

Discussions & Summary

10 STEPS TO ESTABLISH AN ISMS

CONSOLIDATED STEPS

- (1) Define, release and maintain a security, business continuity, and risk policy
- (2) Obtain security requirements and protection requirements (*e.g., conduct vulnerability analysis*)
- (3) Map security requirements to processes, resources, products and programs in the organization
- (4) Develop a security architecture and a security strategy to clarify methodologies
- (5) Create security policies (*e.g., cyber security policy*), guidelines, and apply standards
- (6) Derive particular security concepts and align it with recognized standards
- (7) Implement security controls (*both organizational and technical*)
- (8) Integrate security into the system **lifecycle** (*e.g., NIST SP 800-64*)
- (9) Build a security control circuit
- (10) Install the security management process and maintain it



PROCESS TO IMPLEMENT AN ISMS BY ITRADAT ET AL.

- Management support
- Identify assets
- Review measures to get certified
- Conduct Audit
- Receive ISO 27001 certificate
- Required Processes
- Necessary Documentation

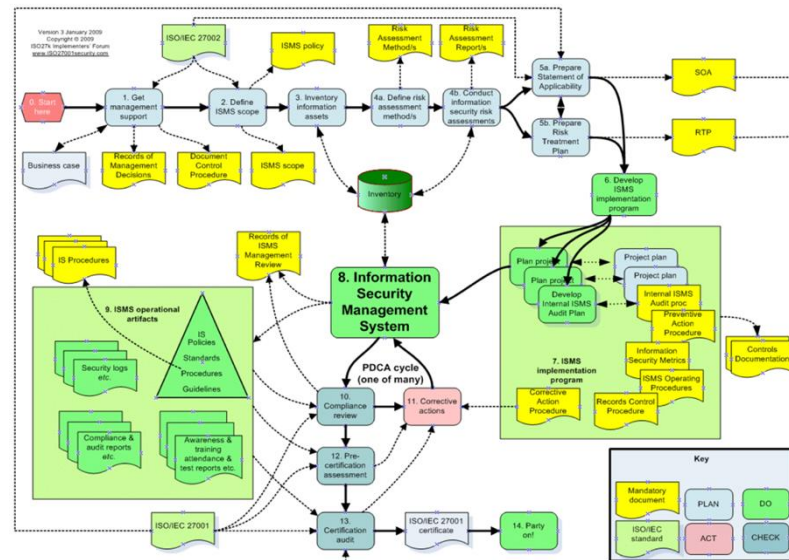


Figure taken from (Itradat, et al., 2014)

WHAT ARE THE CORE PROCESSES OF AN ISMS?

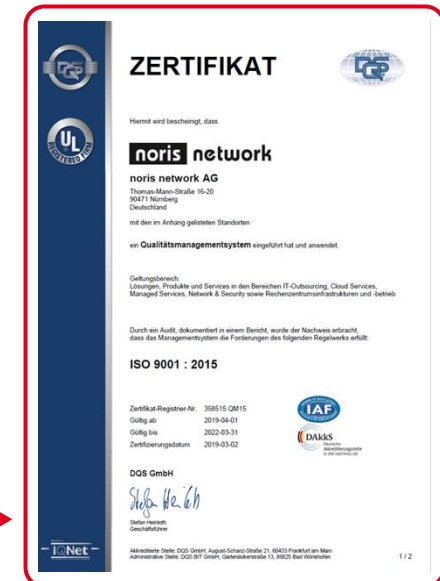
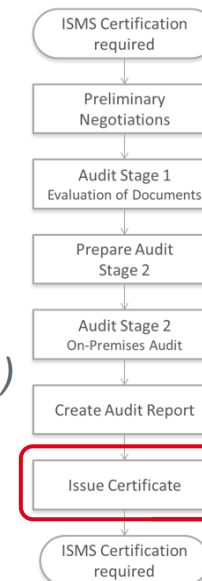
PROCESS-ORIENTED ISMS

- Continuous improvement process
- Information security risk assessment process¹
- Process to assure necessary awareness and competence¹
- Process to control outsourced processes¹
- Internal audit process¹
- Information security incident management process¹
- Information security risk treatment process¹
- Information security improvement process¹
- Information security customer relationship management process¹
- Performance evaluation process¹
- Information security change management process¹

¹ cf. (Haufe, K., et. al, 2016, p. 344)

GENERAL PROCESS TO ACHIEVE A CERTIFICATION ISO 27001

- Accredited third party conducts the certification
- Defined scope of the organisation (e.g., data center)
- Consider results of internal audits (or self assessments)
- Issuing certificate (e.g., Noris network AG¹)



¹ Retrievable: <https://www.noris.de/unternehmen/zertifizierungen/zertifizierungen/>

ROLES UNDER AN ISMS

SELECTED EXAMPLES

Typically assigned and defined by C-level with clarified accountability and responsibility

- **Chief Information Security Officer (CISO)**
- Chief Information Security Manager (CISM)
- ISO (*Information Security Officer*)
- Information Risk manager (IRM)
- Data protection officer (DPO)
- Business Continuity Manager
- Corporate Risk Manager/Officer (CRO)
- [...]

RESPONSIBILITIES OF A CISO

SELECTED EXAMPLES

- Direct report (*e.g., ISMS performance*) to CIO¹ or COO² (*experience: not very often to CEO*)
- Information security leader
- Create security guidelines
- Maintain the ISMS
- Establish risk management process
- Conduct internal and external audits
- [...]

¹ CIO – Chief Information Officer

² COO – Chief Operating Officer

REQUIREMENTS FOR INFORMATION SECURITY POLICIES

4 SELECTED REQUIREMENTS

- Completeness of the policies
- Policies should be well-known and accessible
- Policies should be understood and have to be lived on a daily basis
- Conduct audits and inspections to follow established policies

PRACTICAL EXAMPLES

INFORMATION SECURITY POLICIES

- Strategic Guidelines
- Information Security Policy
- Information Security Organisation
- Risk Management Policy – General Risk Management and Supply Chain Risks
- Lifecycle of Systems – Information Security Policy to Purchase, Develop, Operate and Dispose Software Intensive Products
- Outsourcing Policy
- Business Continuity Management
- Data Protection
- [...]

WHAT CAN WE DO IN TERMS OF SECURITY POLICIES?

ISO/IEC 27001 | ANNEX 5

Annex 5 Information Security Policies

- Create and communicate information security policies
- Deliver information security policies to the relevant stakeholders
- Review the information security policies regularly
- Evaluate the level of implementation of information security policies
- Derive gaps and missing information security policies

HOW CAN WE ORGANIZE INFORMATION SECURITY?

ISO/IEC 27001 | ANNEX 6

Annex 6 Organization of Information Security

- Create a role-based access-control system
- Specify and allocate responsibilities
- Separate duties and avoid conflicts of interest
- Establish processes with authorities (*e.g., reporting*)

OTHER RELEVANT ANNEXES

SELECTED EXAMPLES CONSOLIDATED

Annex 7 Human Resources Security (e.g., background check **BEFORE** employment)

Annex 8 Asset Management (e.g., asset identification, ownership, disposal, classified information)

Annex 9 Access Control (e.g., policy, password handling, role-based access, audit, dev-environment)

Annex 10 Cryptographic Control (e.g., encryption policy?, key management, latest versions)

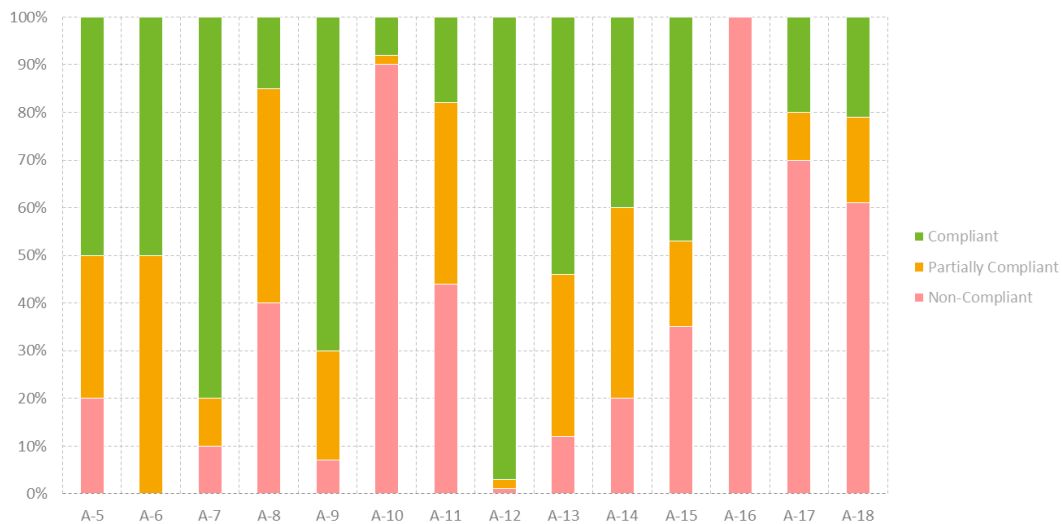
[...]

SAMPLE CLASSIFICATION SCHEME

GAP-ASSESSMENT | SELECTED EXAMPLE

- Annexes
- 3 Categories
- Mapping
- Consolidated
- Overview
- Big Picture

Exhibit | Finding Chart of Identified ISMS Control Groups



Own figure

Compliant

Partially
Compliant

Non-
Compliant

Agenda

Introduction

ISMS – Fundamental Principles about ISO/IEC 2700x

Building an ISMS – Processes, Documentation, Facts

Practical Experiences from Conducted Projects

Discussions & Summary

CRITICAL SUCCESS FACTORS FOR ISMS OBSERVATIONS

- A targeted Information Security Management organization and structure are key success factors
- Enough resources for the organization have to be allocated by management
- Human resources are a key-factor and challenging
- Information Security Management organization has to follow the business organization to be efficient

BENEFITS OF AN ISMS UNDER ISO/IEC 27001

PRACTICAL OBSERVATIONS

- Continuous improvement of traceable information security
- Increased stability of operated IT services and compliance
- Defined responsibilities and accountability particularly in terms of emergencies or crises
- Measure the status of information security and document it
- Defines the concrete characteristics and requirements in terms of information security
- Provides concrete measures (*or security controls*) to achieve the target level of information security on a daily basis
- Make the information security status visible and hold in an upright position (*e.g., to decrease costs*)
- Maintain the status achieved for the future with less efforts than „*BSI Grundschutz*“

DISADVANTAGES OF AN ISMS UNDER ISO/IEC 27001

PRACTICAL OBSERVATIONS

- High documentation efforts required (*e.g., paper, processes, definitions, policies*)
- „*Security management by own specification*“ and „*standard-lock-in*“
- Not very particular security requirements nor controls defined (*e.g., by contrast to „IT-Grundschutz“ ISO/IEC 27001 is more conceptual*)
- High certification and corresponding maintenance efforts („*re-certification lock-in*“)
- Might require too much documentation efforts for small companies
- A full risk analysis is mandatory and ISO/IEC 27001 relies primarily on it
- Continuous assessment of implemented processes

ORGANIZATIONS HAVE TO DEAL WITH ISSUES

INTERNAL AND EXTERNAL FACTORS

Factors that an organization can control (*internal*)

- Available resources (*know whats available to implement information security*)
- Organizational structure (*roles, responsibilities, hierarchy, accountability*)
- Organizational culture (*expressed in terms of mission, vision, values*)

Factors that an organization cannot control (*external*)

- Legislative bases and regulatory requirements (*very important in practice*)
- Political and economical environment (*monitoring useful*)
- Technology development, trends and impacts (*new solutions but new problems?*)

IMPLEMENTED ISMS DIVERGE

PROBLEMATIC CHARACTERISTICS OF ORGANISATIONS

- Heterogeneous organisations develop, and maintain different ISMS
- Heterogeneity problematic if two organisations develop and operate critical systems together
- Complex communication between organisations
- Varying processes make it hard to synchronize communication, particularly in case of emergency or crises

PRACTICAL EXAMPLE

- A1
- AT&T
- **Noris Network AG¹**
- Kapsch Business Comm
- Raiffeisen
- „Qualified Trustcenters“ under eIDAS
- [...]



¹ Retrievable: https://www.bsi.bund.de/DE/Themen/ZertifizierungundAnerkennung/Managementsystemzertifizierung/Zertifizierung27001/ErteilteZertifikate/iso27001zertifikate_node.html

PRACTICALLY IMPLEMENTED CONTROLS

SELECTED EXAMPLES

- Implemented and maintained 27001 ISMS
- Physical protection (*e.g., CCTV, electronic access control, location, premises, security turnstile, separated internal security zones, cage*)
- Multi-factor authentication (*e.g., 3-factor authentication with 3 independent factors*)
- Access only for pre-registered and authorized personnel
- 2 physically separated sites with different risk profile
- Fully redundant (*or independent*) power supply
- Fire and/or water detection system

Agenda

Introduction

ISMS – Fundamental Principles about ISO/IEC 2700x

Building an ISMS – Processes, Documentation, Facts

Practical Experiences from Conducted Projects

Discussions & Summary

SUMMARY

COVERED TOPICS

- Clarified ISO/IEC 27001 fundamentals and the big picture for this standards family
- Investigated practically applicable processes to implement an ISMS
- Explained ISO/IEC 27001 implementation and certification references
- Showed details about concrete roles and concrete document structure under an ISMS
- Demonstrated a concrete audit plan under 27001 for an EiO security assessment
- Discussed practical experiences from conducted projects
- Critiqued advantages and shortcomings of an ISMS and a certification

